

ADENDA

Como parte de la operación de la norma ISO 37301, es necesario establecer un mecanismo de denuncia y un canal de comunicación.

La Ley 2/2023, de 20 de febrero, reguladora de la protección de las personas que informen sobre infracciones normativas y de lucha contra la corrupción, traspone la Directiva 2019/1937 de la UE, conocida como la “Directiva Whistleblowing”. Esta ley convierte el canal de denuncias en una **obligación legal específica** para un gran número de empresas (incluyendo todas las de más de 50 trabajadores) y para todo el sector público. Ya no es solo una buena práctica o un requisito de un estándar voluntario (como la ISO), sino una obligación legal con requisitos muy detallados sobre su gestión, confidencialidad, plazos de respuesta y protección al informante.

El "entorno regulatorio" sobre *compliance*, descrito con carácter genérico en los materiales, podría enriquecerse mencionando normativas de ciberseguridad clave que han aparecido o se han consolidado desde 2022:

1. **Directiva NIS 2 (Directiva (UE) 2022/2555)**: Es la evolución de la directiva NIS. Expande enormemente el número de sectores afectados e impone requisitos de gestión de riesgos y notificación de incidentes mucho más estrictos.
2. **Reglamento DORA (Reglamento (UE) 2022/2554)**: Trata sobre la resiliencia operativa digital del sector financiero. Aunque aplica directamente a entidades financieras, también impone requisitos a los **proveedores de servicios TIC críticos** para dicho sector.
3. **Ley de Ciberresiliencia (CRA - Cyber Resilience Act)**: Aunque aún en desarrollo en la fecha del documento, es fundamental. Establecerá requisitos de ciberseguridad para productos con elementos digitales.